

Develop and Apply Risk Management Strategies

Risk assessment, treatment, mitigation, and monitoring built from the existing DeRexi vulnerability scan

ASSIGNMENT OBJECTIVE

Use vulnerability-scan results to identify and assess two critical business risks, recommend risk treatment and mitigation steps, and define one monitoring procedure that shows how DeRexi will track the risks over time.

1. Evidence basis from the vulnerability assessment

The authorized classroom Nmap assessment identified 10 active hosts in 10.11.2.0/24. The selected DeRexi application server, 10.11.2.144, exposed SSH on TCP/22; the captured vulnerability scripts did not confirm a target-specific vulnerability. The scan finding itself is low/informational, but the business risk can still be high because the server is treated as a critical DeRexi asset.

Scan evidence	Observed result	Risk meaning
Host discovery	10 active hosts	Confirms reachable assets that require inventory and control.
Service enumeration	SSH / TCP 22 open on 10.11.2.144	Creates a remote administrative path that must be tightly controlled.
Vulnerability scripts	No confirmed target-specific vulnerability	Risk treatment should focus on hardening, validation, and monitoring rather than claiming an unproven CVE.

2. Critical risk #1 - Unauthorized privileged access

Risk statement	If SSH is reachable and administrative controls are weak or misconfigured, an attacker could obtain privileged access to the DeRexi application server.
Inherent rating	CRITICAL - likelihood: possible; impact: severe because administrator access can affect confidentiality, integrity, and availability.
Treatment	Reduce the risk.
Recommendations	Restrict SSH to an approved administrative network or VPN/bastion; require key-based authentication and MFA where supported; disable shared/root logins; maintain patch currency.
Mitigation steps	Apply firewall ACLs, verify administrator allowlists, review SSH configuration, alert on repeated failures/unusual sources, and disable TCP/22 if administration does not require it.

IMPORTANT DISTINCTION

The Nmap finding was not itself a critical vulnerability. The critical rating here describes the business impact of a successful compromise of a critical administrative path - not a claim that Nmap discovered a critical CVE.

3. Critical risk #2 - Policy integrity and service disruption

Risk statement	If privileged access to the critical DeRexi server is compromised, an attacker could alter policy content or configuration, disrupt service, or tamper with incident guidance.
Inherent rating	CRITICAL - likelihood: possible; impact: severe because employees and banking clients depend on accurate, available policy guidance.
Treatment	Reduce and contain the risk.
Recommendations	Use RBAC and least privilege, version-controlled policy records, file/configuration integrity monitoring, protected backups, network segmentation, and centralized audit logging.
Mitigation steps	Separate employee and administrator access; log policy/admin changes; preserve trusted versions/hashes; test restoration; alert on unauthorized changes or service outages; maintain tenant/client boundaries.

4. Risk monitoring procedure

Control / metric	Frequency	Trigger	Action / owner
SSH authentication logs	Continuous / daily review	5+ failures in 10 min, unusual source, off-hours admin access	Create alert; Lucy validates account/source and disables access if suspicious.
Port / service validation	Weekly	TCP/22 exposed outside approved admin path	Restrict firewall/ACL immediately and document change.
Vulnerability scan	Monthly + after major changes	New high/critical CVE or unexpected service	Open remediation item; patch, harden, or isolate according to severity.
Policy/admin change logs	Continuous	Unauthorized or unexpected policy/configuration change	Preserve evidence, restore trusted version, escalate as integrity incident.
Risk register review	Monthly	Control overdue, repeated alert, or risk rating increases	Update treatment status, owner, due date, and residual-risk rating.

MONITORING WORKFLOW

SCAN / LOG -> COMPARE TO THRESHOLD -> CREATE ALERT -> TRIAGE -> APPLY CONTROL -> UPDATE RISK REGISTER -> RE-SCAN. The process tracks whether the risk is increasing, stable, or reduced after treatment.

5. Conclusion

Assignment #4 expands the earlier vulnerability assessment into risk management. The scan did not prove a critical vulnerability; instead, it identified a remote administrative exposure on a critical asset. DeRexi therefore treats unauthorized privileged access and the resulting integrity/availability consequences as critical business-risk scenarios, applies layered controls, and monitors those risks through authentication logs, recurring scans, change monitoring, and a maintained risk register.

SOURCE BASIS DeRexi Vulnerability Assessment Report; DeRexi Access Control Measures Report; DeRexi Core System Components.